

TLP: CLEAR

Qilin / Spoonful of Comfort — Premium Intelligence Canary

qilin-spoonful-of-comfort-premium-canary

NON-PRODUCTION RENDER-QA PREVIEW

Generated 2026-08-17T20:18:15.649Z

NOT the customer-facing deliverable

Table of Contents

1. Executive Summary
2. Scope and Methodology
3. Victim Claim Record
4. Actor Overview: Qilin (RaaS Family)
5. RaaS Operating Model: Water Galura
6. Actor Ecosystem Complexity: Moonstone Sleet
7. Documented Campaign Chronology (2023-2025)
8. Tactics, Techniques, and Procedures (ATT&CK-Mapped)
9. Detection
10. Hunting
11. Forecast
12. Alternative Hypotheses
13. Regulatory Considerations
14. Generic Defensive Readiness (GENERIC_DEFENSIVE_READINESS)
15. Intelligence Gaps
16. Technical Recommendations
17. Appendix A: Sources & Evidence Ledger

Qilin / 'Spoonful of Comfort' — Premium Intelligence Canary

Classification: TLP:CLEAR — public leak-site claim and open-source actor intelligence

Executive Summary

On 2026-08-16, a group identifying itself as Qilin listed 'Spoonful of Comfort', a US hospitality-sector business, on its Tor extortion leak site. This is a single-source claim; no independent confirmation, victim statement, regulator filing, or data sample has been located. Real, directly-sourced actor context shows Qilin operating as a ransomware-as-a-service platform run by an operator group MITRE ATT&CK tracks as Water Galura, with a documented, escalating three-year campaign chronology (2023-2025) spanning manufacturing, government, healthcare, and charity sectors across multiple continents -- and, notably, MITRE's own documentation that at least one differently-motivated, state-linked actor (Moonstone Sleet) has independently deployed the same ransomware payload. None of this actor-level context is evidence of what happened, if anything, at Spoonful of Comfort specifically.

Scope and Methodology

This report synthesizes five independently retrieved sources, all fetched as raw bytes via direct HTTP fetch with content_sha256 computed programmatically from the checked-in raw files, never hand-typed: the leak-site aggregator hendryadrian.com (the victim claim itself), Wikipedia's 'Qilin (cybercrime group)' article (a tertiary source citing Trend Micro and Group-IB, with a real named campaign chronology), and three official MITRE ATT&CK pages -- the Qilin software profile (S1242), the Water Galura operator-group profile (G1050), and the Moonstone Sleet operator-group profile (G1036). Every claim in this report traces to at least one of these five sources via an explicit evidence_refs/source_refs chain, visible in the Sources & Evidence Ledger appendix below. No claim in this report is drawn from model memory or generic industry knowledge about ransomware conventions in general -- every specific figure, date, technique ID, and quote is source-anchored. Victim-specific observations (this incident only) are kept structurally and narratively separate from actor-historical context (what is known about Qilin/Water Galura in general) throughout.

Victim Claim Record

Claim posted 2026-08-16 18:56:20 UTC on Qilin's Tor leak site. Sector: hospitality (per aggregator categorization). Country: United States. The claim describes 'unauthorized access and disruption of operations' without specifying what data, if any, was taken. No proof sample was reviewed. Whether a compromise actually occurred is UNKNOWN on current evidence -- this report does not assert it did. The aggregating source's own disclaimer is preserved here rather than smoothed over: 'This post is based on public claims made by the ransomware group qilin. I cannot confirm the accuracy of the information.'

Actor Overview: Qilin (RaaS Family)

Qilin is a ransomware-as-a-service family active since at least 2022, with variants written in Go and Rust targeting Windows, Linux, and VMware ESXi, per MITRE ATT&CK's own consolidated capability profile. Originally detected by Trend Micro in August 2022 under the name 'Agenda' -- Go-language code Trend Micro assessed at the time as resembling Black Basta, BlackMatter, and REvil -- the payload was rewritten in Rust by December 2022. MITRE's current, more recent assessment describes an overlapping but not identical family comparison: Black Basta, REvil, and BlackCat. Both assessments are reported here as separate, independently attributable analytic judgments taken roughly three years apart, rather than merged into a single figure. MITRE records the majority of Qilin's documented victims as being in the US, France, Canada, and the UK, primarily in manufacturing, technology, financial services, and healthcare -- an aggregate industry-level statement, not a claim about any specific victim.

RaaS Operating Model: Water Galura

MITRE ATT&CK tracks the operators of the Qilin RaaS platform as Water Galura (G1050, alias GOLD FEATHER): the group handling payload generation, ransom negotiation, and publication of stolen data for affiliates recruited on Russian cybercrime forums, using a double-extortion model, active since at least 2022. Water Galura operates a Telegram news channel to announce the RaaS to prospective affiliates, and directly extorts victims for both decryption keys and to prevent publication of exfiltrated data to their Tor leak site. Separately, Group-IB's March 2023 infiltration of Qilin's affiliate panel found that affiliates retain approximately 80-85% of each ransom payment -- a real, quantified data point on the RaaS's own economics, consistent with the broad, high-volume affiliate model MITRE's own profile describes.

Actor Ecosystem Complexity: Moonstone Sleet

A RaaS brand is not always a single operator. MITRE ATT&CK separately records Moonstone Sleet (G1036, alias Storm-1789) -- a North Korean-linked threat actor conducting both financially motivated attacks and espionage, which previously overlapped significantly with the Lazarus Group before differentiating its tradecraft since 2023 -- as having deployed Qilin ransomware, citing a 2025-03-06 Microsoft Threat Intelligence social-media post as MITRE's own source. That underlying post was not independently retrieved this session, so this claim is represented as REPORTED rather than CONFIRMED. This is included strictly as actor-ECOSYSTEM context: it demonstrates that more than one kind of operator can be behind a Qilin-branded incident, not that Moonstone Sleet, or any specific actor, is connected to Spoonful of Comfort -- no source reviewed makes that connection.

Documented Campaign Chronology (2023-2025)

Wikipedia's article (citing open-source reporting) documents a real, escalating, named campaign history. **2023:** Thornburi Energy Storage Systems (battery manufacturer, Thailand), construction consultancy WT Partnership Asia, and Chinese car-parts manufacturer Yanfen (affecting operations at US automaker Stellantis). **2024:** Upper Merion Township (US, ~500 GB claimed stolen), Felda Global Ventures Holdings Berhad (Malaysia), the Big Issue (UK charity, 550 GB claimed stolen), Skender Construction (US, 651 GB claimed stolen impacting 1,067 people, including names, addresses, dates of birth, payment details, and passports), and a critical incident declared by several London hospitals. **2025:** Inotiv (US, 178 GB claimed stolen), Asahi (major Japanese brewery, October 2025), Academie d'Amiens (Hauts-de-France, France, more than 1TB claimed stolen -- the largest attack attributed to Qilin to date), and Covenant Health (healthcare, June 2025, reportedly impacting more than 478,000 individuals). None of these prior incidents is evidence about Spoonful of Comfort; they establish the actor's documented operating pattern and scale.

Tactics, Techniques, and Procedures (ATT&CK-Mapped)

MITRE ATT&CK documents Qilin's capability across the full attack lifecycle, quoted directly here. **Initial access (T1190, T1566.001, T1566.002):** exploitation of exposed Citrix and RDP interfaces, and delivery via spearphishing attachments and links. **Credential access and lateral movement (T1003.001, T1570, T1021.002, T1021.004):** an embedded Mimikatz module for LSASS memory dumping; PsExec-based distribution of a second encryptor; PsExec embedded in the %Temp% directory under a randomly generated filename; and enabling SSH access on ESXi hosts. **Defense evasion (T1070.004, T1685/T1685.005, T1036.004/.005):** self-deletion after execution; termination of antivirus-related processes and clearing of Windows Event Logs; and masquerading via a scheduled task named 'TVInstallRestore' and a payload file named 'TeamViewer_Host_Setup'. **Impact (T1486, T1490):** AES-256 or ChaCha20 domain-wide encryption with RSA-4096/RSA-2048 key protection; execution of 'vssadmin.exe delete shadows /all /quiet'; and disabling vCenter High Availability and Distributed Resource Scheduler. All of this is documented CAPABILITY -- no TTP specific to this incident has been observed by any source reviewed.

Detection

A Sigma detection concept is provided at SYNTAX_VALIDATED maturity only -- neither lab testing nor any deployment validation has been performed this session -- targeting two of Qilin's own documented, quotable indicators: the 'vssadmin.exe delete shadows /all /quiet' command line and creation of a scheduled task named 'TVInstallRestore'. A match does not by itself confirm Qilin attribution; both are documented ransomware/impact-stage indicators that could theoretically appear in other contexts (see the rule's own falsepositives field). Full rule body:

YAML

```
title: Qilin Ransomware Shadow-Copy Deletion and TVInstallRestore Scheduled-Task Masquerade
id: reportx-canary-qilin-vssadmin-tvinstallrestore
status: experimental
description: >
  Detects two command-line indicators documented for the Qilin ransomware
  family: vssadmin.exe invoked to delete all shadow copies, and creation
  of a scheduled task named TVInstallRestore used to masquerade as a
  legitimate TeamViewer maintenance task. Either indicator alone is a
  strong ransomware impact-stage signal; this rule does not by itself
  confirm Qilin/Water Galura attribution for any specific incident.
references:
  - https://attack.mitre.org/software/S1242/
  - https://attack.mitre.org/groups/G1050/
logsource:
  category: process_creation
  product: windows
detection:
  selection_vssadmin:
    Image|endswith: '\vssadmin.exe'
    CommandLine|contains|all:
      - 'delete'
      - 'shadows'
      - '/all'
      - '/quiet'
  selection_scheduled_task:
    CommandLine|contains: 'TVInstallRestore'
  condition: selection_vssadmin or selection_scheduled_task
falsepositives:
  - Legitimate backup/shadow-copy maintenance scripts using the same vssadmin syntax
  - Unrelated scheduled tasks that happen to share a similar naming convention
level: high
```

Hunting

Given the documented, specific naming conventions in Qilin's masquerading TTPs, a defensible hunting hypothesis is to search endpoint process and file-creation telemetry for the exact strings 'TVInstallRestore' and 'TeamViewer_Host_Setup' outside of genuine TeamViewer installation activity, and to search command-line telemetry for PsExec invocations sourced from randomly-named files inside %Temp% rather than a standard PsExec installation path. Separately, given Water Galura's documented use of SSH enablement on ESXi hosts (T1021.004), hunting teams operating VMware environments should review ESXi SSH-service enable/disable audit logs for unexpected activation events outside of planned maintenance windows. This report does not include incident-specific IOCs for Spoonful of Comfort -- none were located by any source reviewed.

Forecast

MEDIUM confidence that Qilin-branded activity will continue at or above its documented 2023-2025 pace over the next 90 days, with continued targeting spanning hospitality/services alongside its historically dominant sectors -- tempered by the inherent unpredictability of law-enforcement disruption events and by this review's own finding that the RaaS brand's affiliate base is not monolithic. See the structured forecast record (supporting observations, assumptions, alternative scenarios, and indicators to watch) in this bundle's **forecasts** field.

Alternative Hypotheses

Two genuinely open analytic questions are weighed explicitly rather than resolved by assumption. **First**, whether the leak-site listing reflects a genuine, currently-undisclosed compromise (**H1**, consistent with Water Galura's documented double-extortion playbook) versus an unconfirmed or overstated claim (**H2**, consistent with the total absence of a proof sample, independent confirmation, or victim acknowledgement). **Second**, if a compromise did occur, whether it was carried out by a standard, financially-motivated Water-Galura-recruited affiliate (**H1**, consistent with the overwhelming majority of Qilin's documented campaign) versus a non-standard operator such as Moonstone Sleet (**H2**, which cannot be ruled out given MITRE's own documentation but has no source connecting it specifically to this incident).

Regulatory Considerations

HIPAA is assessed NOT_APPLICABLE: Spoonful of Comfort is a hospitality/specialty-gifting business with no established healthcare nexus, explicitly distinguished from Covenant Health, a genuinely healthcare-sector Qilin-attributed 2025 victim named in the campaign chronology above. US state data-breach notification statutes and PCI-DSS are both assessed NOT_ASSESSED: notification and cardholder-data-environment obligations depend on which specific data, if any, was actually accessed, and that fact is UNKNOWN on current evidence. The SEC Cyber Disclosure Rule is assessed NOT_APPLICABLE: no source reviewed establishes Spoonful of Comfort as a US public company.

Generic Defensive Readiness (GENERIC_DEFENSIVE_READINESS)

Standard ransomware readiness guidance -- immutable backups, MFA and ESXi SSH-access hardening, network segmentation isolating management interfaces, behavioral detection for mass encryption and the specific vssadmin command line, monitoring for shadow-copy/HA/DRS/event-log tampering, and a tested IR plan with a defined leak-site-monitoring process -- is provided as general hardening grounded in Qilin's own documented TTPs, not as evidence any specific technique was used against this victim.

Intelligence Gaps

Seven gaps are explicitly unresolved by any source reviewed for this report: victim acknowledgement is unavailable; no incident-specific IOCs were observed; no proof sample of the claimed stolen data exists; no independent confirmation of the leak-site claim was located; no initial-access or incident-specific TTP evidence was found; whether any of Qilin's documented general TTPs were used in this specific incident is unestablished; and which specific actor or affiliate is responsible for this claim -- a standard Water-Galura-recruited affiliate or a non-standard operator -- is unestablished.

Technical Recommendations

1. Maintain immutable, tested, offline backups as the direct countermeasure to Qilin's documented shadow-copy-deletion and vCenter HA/DRS-disabling behavior (evidence: c-ttp-impact).
2. Harden ESXi/vCenter management interfaces -- disable unnecessary SSH access and monitor for unexpected SSH-enablement events -- against Qilin's documented ESXi-targeting TTPs (evidence: c-ttp-credential-lateral, c-ttp-impact).
3. Deploy monitoring for Qilin's specific documented masquerading indicators ('TVInstallRestore', 'TeamViewer_Host_Setup') via the detection rule above (evidence: c-ttp-defense-evasion).

Appendix A: Sources & Evidence Ledger

Every source registered in this report's evidence graph, its retrieval/integrity metadata, and every captured excerpt tied to it -- the complete evidentiary basis for every claim above.

s-hendryadrian — hendryadrian.com (ransomware leak-site aggregator)

- URL: <https://www.hendryadrian.com/ransom-spoonful-of-comfort-aug-2026/>
- Type: LEAK_SITE_AGGREGATOR
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 54f60988474da10916c25858d55a4c4f9894148d3680017e0d393cb40a1c70cb

Victim: Spoonful of Comfort. Sector: Hospitality. Country: US. Actor: qilin. Published: 2026-08-16T18:56:20.892782+00:00. Information: Spoonful of Comfort was targeted by the Qilin ransomware group in the US. Disclaimer: This post is based on public claims made by the ransomware group 'qilin'. I cannot confirm the accuracy of the information.

Spoonful of Comfort in the US reported a ransomware incident allegedly linked to the qilin threat actor, resulting in unauthorized access and disruption of operations.

s-wikipedia-qilin — Wikipedia

- URL: [https://en.wikipedia.org/wiki/Qilin_\(cybercrime_group\)](https://en.wikipedia.org/wiki/Qilin_(cybercrime_group))
- Type: OTHER
- Reliability: MODERATE
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 4f09fb3af9c3de8d28c133b781ddfef942ec21f844725b21f58a84e75ea04e90

The group was detected by Trend Micro in August 2022 promoting ransomware called Agenda, which affiliates could tailor. The software at the time was written in Go and Trend Micro noted similarity of the source code with Black Basta, Black Matter and REvil families of malware. In December 2022 the Agenda ransomware was rewritten in Rust.

Group-IB said they had infiltrated the group in March 2023 and that affiliates earn about 80 to 85% of each ransom payment.

In 2023, Qilin attacks included the following: Thornburi Energy Storage Systems, a battery manufacturer in Thailand; construction consultancy WT Partnership Asia; Chinese car parts manufacturer Yanfen, which affected operations at US car maker Stellantis.

In 2024, Qilin was named in the following attacks: Upper Merion Township in the United States, where they claimed to have stolen 500 GB including information on staff and private contracts; Felda Global Ventures Holdings Berhad in Malaysia; UK-based charity the Big Issue (550 GB of data stolen including personnel information, contracts and partner data); US business Skender Construction (651 GB of data stolen impacting 1,067 people including names, addresses, dates of birth, payment details, passports and potentially health information); several London hospitals declared a critical incident when a ransomware attack affected their systems.

In 2025, Qilin was named in the following attacks: US business Inotiv (178 GB of data stolen); in October 2025, Qilin claimed responsibility for a ransomware attack on Asahi, a major Japanese brewery; on October 10, the Qilin group attacked infrastructure in the Hauts-de-France region targeting the Academie d'Amiens, with more than 1TB of data stolen -- the largest attack carried out by the Qilin group to date; in June 2025, the Qilin group claimed responsibility for a data breach on healthcare organization Covenant Health, reportedly impacting more than 478,000 individuals.

s-mitre-s1242 — MITRE ATT&CK

- URL: <https://attack.mitre.org/software/S1242/>
- Type: MITRE
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 450d69445e9320530e51278943dc8bfde5516da2b8953e478ea2b31cb2e69148

Qilin is a ransomware family operated as a ransomware-as-a-service (RaaS) that has been active since at least 2022. It includes variants written in Go and Rust capable of targeting Windows, Linux, and VMware ESXi environments. Qilin shares functionality overlaps with Black Basta, REvil, and BlackCat ransomware. Qilin affiliates have targeted multiple entities worldwide with the majority of victims in the US, France, Canada, and the UK, primarily in the manufacturing, technology, financial services, and healthcare sectors.

Qilin shares functionality overlaps with Black Basta, REvil, and BlackCat ransomware.

T1486 Data Encrypted for Impact -- Qilin can use AES-256 or ChaCha20 for domain-wide encryption of victim servers and workstations and RSA-4096 or RSA-2048 to secure generated encryption keys. T1490 Inhibit System Recovery -- Qilin can execute 'vssadmin.exe delete shadows /all /quiet' to remove volume shadow copies and can disable High Availability (HA) and Distributed Resource Scheduler (DRS) in vCenter clusters.

T1003.001 OS Credential Dumping: LSASS Memory -- Qilin can employ an embedded Mimikatz module to dump LSASS memory. T1570 Lateral Tool Transfer -- Qilin has used PsExec to distribute a second encryptor, named encryptor_1.exe, across the targeted environment. T1021.002 Remote Services: SMB/Windows Admin Shares -- Qilin can embed a copy of PsExec within its payload and place it in the %Temp% directory under a randomly generated filename. T1021.004 Remote Services: SSH -- Qilin can enable SSH access on ESXi hosts.

T1070.004 Indicator Removal: File Deletion -- Qilin can delete itself from infected hosts after execution. T1685 Disable or Modify Tools -- Qilin can terminate antivirus-related processes and services; sub-technique .005 Clear Windows Event Logs -- Qilin has the ability to clear Windows Event Logs. T1036.004 Masquerading: Masquerade Task or Service -- Qilin has created a scheduled task named TVInstallRestore to mimic TeamViewer. T1036.005 Masquerading: Match Legitimate Resource Name or Location -- Qilin has named its payload file TeamViewer_Host_Setup to disguise itself as a legitimate TeamViewer file.

T1190 Exploit Public-Facing Application -- Qilin has been delivered through exploitation of exposed applications and interfaces including Citrix and RDP. T1566.001 Phishing: Spearphishing Attachment -- Qilin has been delivered to victims through malicious email attachments. T1566.002 Phishing: Spearphishing Link -- Qilin has been delivered via malicious links in spearphishing emails.

s-mitre-g1050 — MITRE ATT&CK

- URL: <https://attack.mitre.org/groups/G1050/>

- Type: MITRE
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: 59d6407e2a824c927b2c9a83e14899cbd4c04b6e84cad03c876470b242f51216

Water Galura are the operators of the Qilin Ransomware-as-a-Service (RaaS) who handle payload generation, ransom negotiations, and the publication of stolen data for Qilin affiliates recruited on Russian cybercrime forums. Water Galura have been active since at least 2022 and use a double extortion model where they demand payment for providing decryption keys and for refraining from publishing the stolen data to their leak site.

Establish Accounts: Social Media Accounts -- Water Galura operates a news channel on Telegram to make announcements for the Qilin RaaS.

Financial Theft -- Water Galura has extorted victims for ransomware decryption keys and to prevent publication of data exfiltrated to their Tor data leak site.

s-mitre-g1036 — MITRE ATT&CK

- URL: <https://attack.mitre.org/groups/G1036/>
- Type: MITRE
- Reliability: HIGH
- Retrieved: 2026-08-17T00:00:00Z
- content_sha256: d0323e5f5892b3d9cef426bee4720148e50698f94e7e38dce5ed4ae486c767f4

Moonstone Sleet is a North Korean-linked threat actor executing both financially motivated attacks and espionage operations. The group previously overlapped significantly with another North Korean-linked entity, Lazarus Group, but has differentiated its tradecraft since 2023.

Software used: S1242 Qilin -- Moonstone Sleet has deployed Qilin ransomware. [Reference: Microsoft Threat Intelligence (@MsftSecIntel), 2025-03-06, Microsoft Threat Intelligence on X. Retrieved by MITRE 2025-09-26.]